

INSuRE Spring 2023
Final Project Report
Privacy Within Federated Machine Learning Systems
Sponsor: Argonne National Laboratory
Technical Director: Roland Varriale

Final Report

The University of Texas at Dallas

Team 3

Arshia Elahi - Graduate Fourth Semester - mme190002@utdallas.edu
Kumail Bukhari - Graduate Fourth Semester - sxb180119@utdallas.edu
Mason Orsak - Graduate Fourth Semester - mto180000@utdallas.edu
Miranda Ferrer- Graduate Fourth Semester - mx200008@utdallas.edu
Brain Ricks - Faculty Support - absolutejunk@utdallas.edu

May 7, 2023

Table of Contents

1.0 Project Summary	3
1.1 Top Level Project Description	3
1.2 Keywords	3
1.3 Terminology	3
1.4 Team Member Responsibilities	3
1.5 Estimated Project Budget	4
1.6 Summary of Key Deliverables	4
1.7 Motivation	5
2.0 Security Categories	5
2.1 Security Category Progress	5
2.2 Security Considerations	8
2.3 Federated Defenses	8
2.4 Assurance Levels	9
3.0 Future Work	10
4.0 Literature Review	11
4.1 APPFL: Open-Source Software Framework for Privacy-Preserving Federated Learning	11
4.2 Poisoning Deep Learning based Recommender Model in Federated Learning Scenarios	12
4.3 Scanning Electronic Documents for Personally Identifiable Information	12
4.4 Threats to Federated Learning: A Survey	13
4.5 FLCert: Provably Secure Federated Learning against Poisoning Attacks	14
4.6 A Taxonomy of Attacks on Federated Learning	14
5.0 Bibliography	15

1.0 Project Summary

1.1 Top Level Project Description

Federated learning is a machine learning technique where a network of decentralized devices collaborate to train a shared model without exchanging their data. Instead, each device trains a local model using its own data and shares the model parameters with a central server. The server then aggregates the model parameters and updates the shared model. This way, the shared model can be trained on larger datasets while maintaining the privacy of the individual datasets. Privacy-preserving federated machine learning is a subset of federated learning that takes the federated framework and focuses on preserving the confidentiality and integrity of the individual datasets. These increased security requirements however come at a cost, increased time complexity.

Our goal with this project is to recommend different security levels that can be implemented into a federated framework. Each of these levels will be more secure than the last, and in turn also slower than the last. This allows for a much finer grained control over both privacy and time complexity of federated learning environments than was previously available in privacy preserving federated frameworks.

1.2 Keywords

Federated Machine Learning, Privacy-Preserving Federated Machine Learning, Cybersecurity, Datasets, Computer Science, Machine Learning, Personal Identifiable Information

1.3 Terminology

- **Federated Learning:** Federated machine learning is a technique in which multiple decentralized devices collaborate to train a shared model without exchanging their data.
- **Privacy Preserving Federated Learning:** Privacy preserving federated learning is a subfield of federated learning that focuses on increasing confidentiality and integrity of the model parameters shared between the federated nodes.

1.4 Team Member Responsibilities

Arshia Elahi

Arshia will work on researching algorithms for detecting the presence of sensitive information in data, such as algorithms related to text and pattern matching. He will also research the standards for the level of privacy assurances given to data. Arshia will also be responsible for providing key statistics to be used in the presentation. Finally, Arshia will work on finding potential drawbacks of the current encryption of weights and if a better alternative exists.

Kumail Bukhari

Kumail will work on researching privacy standards found in the current literature. He will also further research different standards set in different fields and regions. Kumail will also assist

Arshia in assessing the current frameworks of privacy preserving federated learning as well as research potential improvements to the frameworks. Kumail will also work on generated sample data to be tested against the privacy standards.

Mason Orsak

Mason will serve as the team leader for the project where he will oversee and help coordinate efforts of the team members. This includes ensuring that the project stays on track, tasks are completed in a timely manner, and the team stays in contact in order to properly collaborate on assignments. He will also help prioritize tasks and delegate responsibilities to team members, ensuring that everyone is contributing to the project in an effective and efficient manner. The team lead will serve as the point of contact for both the faculty supervisor and mentor outside of scheduled sessions. Outside of team leader roles, Mason will help assist in completing the current tasks at hand (see 1.6 Summary of Key Deliverables).

Miranda Ferrer

Miranda Ferrer will work with the team to research the different assurance and privacy techniques involved currently in federated learning. She will also research federated learning and the ways it is used now in the world and the different ways it is implemented in regards to cross silo and cross device. She will be responsible for creating the powerpoint presentation, hosting the documents on google drive.

1.5 Estimated Project Budget

We believe that this project can be completed utilizing only existing resources. As students at the University of Texas at Dallas, we have access to numerous subscription-based research platforms, which are available to us at no cost. Furthermore, any additional resources required for the project can be obtained through various free online sources.

1.6 Summary of Key Deliverables

Table 1. Breakdown of Deliverables

Description	Approximate Completion Date
Project Proposal	February 3rd
Phase 1 - literature review	February 17th
Phase 2 - categorize sensitive data and create security requirements, rough draft	March 3rd
Midterm Report/Presentation	March 24th
Phase 3 - finalize data categories and security	April 14th

requirements	
Final Report/Presentation	May 5th

1.7 Motivation

Because of the inevitable boom in big data; consuming, managing, and analyzing data has become rather challenging and complex. Furthermore, this large volume of data comes with privacy concerns. The idea of federated learning allows the datasets to be private and separate from each device and still be able to get results from the machine learning model. By not allowing the data to be in a central device, you reduce the risk of data leaks and ensure the privacy of the consumer. The world we live in today is surrounded by data and we have to make sure it is secure from adversaries without limiting our use of machine learning. It is in our benefit to use machine learning to advance research in several industries. For example, healthcare can benefit from federated learning to classify and identify trends for individuals based upon their attributes without actually knowing their personally identifying information. This idea is based on the concept of passing weights instead of the data itself to the central server. However currently, privacy preserving federated learning frameworks can offer strong privacy guarantees, but these lead to increased time complexity. Not all implementations may need that level of security or can tolerate the resulting slower speeds. And federated frameworks need finer tuned controls over privacy settings to fit individual implementation needs. Furthermore, this field is still relatively new and there is not much of a description in regards to the levels of privacy it can actually guarantee. Ensuring greater levels of privacy without unnecessarily sacrificing time complexity is what motivates us to research this project.

2.0 Security Categories

2.1 Security Category Progress

Our framework for the security categories has evolved through several phases since our first proposal. Initially, while we were still doing our preliminary research, we planned to create 10 different security categories. Each of these would have general classifications for what data and security requirements would belong to each category. For example, level 1 with the lowest security requirements would hold data that has no personal information or intellectual property. Level 5 with medium security requirements would have data such as home addresses, phone numbers, emails, etc. Level 10 with the strictest security requirements would have data such as social security numbers, healthcare data protected by HIPAA, and financial information. However, as our research progressed and with feedback from our sponsor we found two major problems with this approach, first that 10 security levels was likely too fine grained of an approach, and second, the level of privacy people assign to their data is very subjective. The first problem was solved easily by lowering the number of security levels into broader categories but the second problem required us to change how we classify the levels completely. We first began to discover this problem as we refined what data belonged to the security levels. When

discussing what security levels information like gender and sexual orientation should belong to we ran into a problem. For some people this information is public knowledge but for others it can be considered very private. In order to account for such subjectively private data we moved onto phase 2 of our security level definitions.

In this phase we recategorized our security levels down to only four levels which were modeled after how the United States federal government classifies sensitive data: unclassified, classified, secret, and top secret. In this phase we discarded the notion of specifying the types of data used in each category and instead only specify the security constraints. Here we leave the decision for what data best fits into what security level up to whoever is using the federated framework. Next we began looking into current frameworks and research that defined modern security requirements of confidentiality, integrity, and availability. We were hoping to find specific types of encryption and protocol recommendations to help guide our framework, but instead we started to notice a trend of vague recommendations in current frameworks. For example, when looking through the security and privacy definitions for HIPAA, only broad recommendations were made that there should be some mechanisms implemented to enforce confidentiality, integrity, and availability [11]. No specific protocol or encryption method such as Advanced Encryption Standard was mentioned. We found this same vague implementation advice listed in several other popular security frameworks such as the NIST Risk Management Framework and several research papers [12]. We believe these were left intentionally vague in order to allow for ease of adoption and make room for future advancements in cyber security defense, so the frameworks didn't have to be updated every time an encryption vulnerability was found. This made it clear no hard standard existed for specific protocols that we should use for the different privacy levels in federated machine learning, reinforcing the necessity of our project. As we began piecing together some general security levels, our advisor mentioned how our current classification names may cause conflicts with data that is actually classified. He recommended we change it to something more unique, which brought us to the third phase.

Instead of basing our security levels on existing frameworks, which we found too vague to be useful, we began piecing together protocols based on existing privacy preserving federated learning research papers and cyber security literature. Our new four levels of security were titled public, restricted, sensitive, and secure (least to most secure, respectively). Table 2 shows the security level definitions we had at the time of the midterm report.

Table 2. Midterm Report Security Level Definitions

Security Level	Encryption	Integrity	Trusted Server	Federated Defenses
Public	None	Yes	Yes	No
Restricted	Asymmetric key encryption to establish symmetric keys	Yes	Yes	No

Sensitive	Asymmetric key encryption to establish symmetric keys	Yes	No	Differential privacy
Secure	Asymmetric key encryption to establish symmetric keys	Yes	No	Differential privacy, robust aggregation, and outlier detection

The fourth and final phase of our security levels was focused on recommending specific protocols for these categories that were backed by existing literature. A publication we found particularly helpful was the NIST Guideline for Using Cryptographic Standards in the Federal Government which gave a very nice overview of specific protocols currently available to enforce confidentiality, integrity, and availability (including those that are outdated and why) [13]. This was a primary resource in deciding specific protocols to be used for confidentiality and integrity. The real difficulty came with federated defenses where we had to turn to swaths of research in the area. This was particularly a difficult problem for us since federated learning, and especially privacy preserving federated learning, is such a new field and much of the work has yet to be peer reviewed and is contradictory to other research. We discuss these problems and our recommendations in more detail in section 2.3 below. This research coalesced into our final security level definitions listed in table 3.

Table 3. Final Security Level Definitions

Security Level	Integrity	Encryption	Malicious Clients	Malicious Server	Federated Defenses
Public	✓	X	X	X	X
Restricted	✓	✓	X	X	X
Sensitive	✓	✓	✓	X	Robust Aggregation
Secure	✓	✓	✓	✓	Robust Aggregation, Differential Privacy, Privacy Preserving Framework

2.2 Security Considerations

There are several security considerations we keep in mind while developing our security levels. The first consideration is encryption to make sure the weights sent over the open internet

from nodes to the central federated server are protected against unauthorized viewers. Using the slower asymmetric key encryption to establish faster symmetric keys, a well known method to speed up encryption and decryption without sacrificing security [14]. The next consideration is integrity, we want to make sure that the weights sent by the node to the server are not corrupted in transit. Currently we believe the best way to accomplish this encryption and integrity constraint in a single step is to use TLS. The best standards and practices to implement TLS are clearly defined in the NIST SP 800-52r2 publication [15]. We strongly recommend any TLS implementation follow these standards and check if any more up to date publications are available. For example in the 800-52r2 publication they already recommend government agencies make preparations to transfer to TLS 1.3 by January 1, 2024 [15]. This covers the restricted, sensitive, and secure security levels, but the public level includes no encryption. We recommend integrity is enforced at this level by using cryptographic hashing of the data. This method of ensuring integrity is discussed in section 4.1 of the NIST SP 800-57r5 and references the approved cryptographic hash functions [16]. Finally, the secure layer adds the additional protection of homomorphic encryption. Papers have shown that although homomorphic encryption accrues computational overhead, it can make strong guarantees about privacy by having the central server work directly on encrypted data, never decrypting it [18, 19].

Next we have all the security considerations that come with federated learning. We group these into the three main categories model poisoning, data poisoning, and data privacy attacks. Both model poisoning and data poisoning do not violate the privacy of data, but they can violate the accuracy of the model [7]. This can occur in two main ways, first an unauthorized agent injects or replaces weights sent by authorized nodes to the federated server with the goal of globally degrading model performance, or the goal of swaying specific model predictions one way [7]. The category of data privacy attacks can be subdivided into inversion attacks, inference attacks, and reconstructions attacks. Inversion attacks can successfully identify sensitive properties of classes and individual samples represented by the model [8]. For example, an attacker who has basic demographic information can predict medication conditions an individual has when equipped with only the model [7]. Inference attacks are when an attacker infers whether or not a given training example belongs to a specific class within the model. Finally, reconstruction attacks are similar to inversion attacks but more powerful. Here attackers can generate synthetic samples of data that are statistically significant to the training data [9].

2.3 Federated Defenses

Many federated defenses have been proposed in order to protect the model accuracy and privacy of data [7]. The defenses we plan to implement are broadly grouped into three categories, differential privacy, robust aggregation, and privacy preserving frameworks.

Differential privacy (DP) is a mathematical guarantee that limits the amount of information revealed about a single entry in a database [17]. This is accomplished by adding noise to the data or using regularization techniques to bound the information contributed by clients. There are generally two types of differential privacy implementations, local and central. Local DP has the client nodes add noise or regularize before the weights are sent to the central

server. Central DF on the other hand has a separate trusted server add noise or regularize on behalf of all the clients. Which option works best really depends on the specific federated implementation. For example, different departments of the same college campus sharing data would likely have a central server that they all trust which could implement DP. On the other hand if you have thousands of devices all participating in federated learning from users all over the country, it's unlikely they could all trust a single server, so local DP might be a better solution. While differential privacy is a popular and strong method of protecting user data in federated environments, there have been attacks that are still able to leak data, even in the presence of secure aggregation [7, 20, 21]. While concerning, and continuing research into better methods is needed, we still believe this to be a valuable method of protecting data because the conditions needed to launch these attacks are very specific and complex. We believe it's unlikely, especially in the face of our other federated learning defenses, user privacy will be violated.

Federated learning relies heavily on aggregation algorithms. Unfortunately traditional Byzantine-robust algorithms are vulnerable to network instabilities, such as client dropouts, which is common when federated learning amongst IoT devices [17]. Thankfully robust aggregation comes to the rescue. Robust aggregation techniques, like adaptive aggregation, can detect and reject corrupted updates from a fraction of clients [22, 23]. These techniques have been shown to be very successful at detecting byzantine adversarial clients attempting to corrupt the model. Some attacks to have been defeated by aggregation algorithms include poisoning attacks, label-flipping, and backdoor attacks [23, 24].

Finally, privacy preserving frameworks have been built that implement a multitude of privacy preserving algorithms, both known and original, in order to protect user data and model accuracy. There are many to choose from and even more being developed. Some of these include Argonne Privacy-Preserving Federated Learning (APPFL) framework, HybridAlpha, chain-PPFL, and PFLF [1, 25, 26, 27]. By protecting user data, these frameworks can help to build trust between participants in a federated learning setting, which can ultimately lead to more widespread adoption of the technique. Many of these frameworks use techniques already discussed previously in this paper, in which case they do not need to be reimplemented separately.

2.4 Assurance Levels

The public security level makes no assurance about the privacy of the data. It is meant for federated data that holds no sensitive information or intellectual property since it's sent in an unencrypted fashion across the open internet. Here we implement no federated defenses since we trust both the central server doing the training and that there are no malicious clients. For example, this security level may be a good choice for students doing a project of federated learning where they own all participating devices the data used is already publicly available.

The restricted security level builds on the public security level by incorporating encryption to protect the communication with the central server from unauthorized viewing. Here we ensure data will be protected from viewing during transit and protected from corruption using integrity constraints. However there is still no federated defense put in place, so both the

central server and the participating client nodes must be trusted. An example use case for this level would be two different college departments participating in federated learning. The weight updates will be sent over the open internet and the universities would like to protect their intellectual property from theft and tampering, so encryption and integrity is necessary. But since these two universities have a long history of collaboration, all clients and the central server are trusted.

The sensitive security level adds the federated defense of differential privacy to protect against an untrusted central server from learning about client data. Both encryption and integrity constraints are used to protect against revealing private data and tampering during transit. However, the client nodes must still be trusted to not tamper with the model since differential privacy offers no protection against data and model poisoning. A use case here could be two companies collaborating using federated learning to build a model to better predict which products to recommend to users. Data is sent across the internet so encryption and integrity constraints are required. Company B does not trust company A who is hosting the central server with private client data, so differential privacy is needed. Both companies however trust that each other will not participate in data or model poisoning since it would degrade the accuracy of the model they both plan to use.

The highest level of security, the secure level, has all the protections of all previous levels except it also incorporates data and model poisoning protections for when client nodes may not be trusted, as well as homomorphic encryption to further protect against data recovery by malicious entities. Here we have several federated defenses, differential privacy, robust aggregation, and the use of privacy preserving federated frameworks. Each of these is discussed in more detail in the previous section. The particular framework chosen is left up to the parties participating in the federated system. We recommend double checking for new frameworks or updates to existing frameworks since this field is still a active area of research. A use case for this security level might be, for example, an independent company building a federated model using many IoT devices produced by companies all over the world. The client's IoT device data is sent over the internet and is protected with encryption and integrity constraints. It must also be protected from being revealed to the central server so differential privacy is used. Finally a minority of IoT devices may send incorrect or falsified data, so model and data poisoning protections must be put into place. Additional defenses to ensure accuracy of the model and protection of user data is achieved by using homomorphic encryption and the chosen privacy preserving federated framework.

3.0 Future Work

We believe the next logical step from the research we've done here is to provide more assurance that the security levels we've recommended are not only as good at keeping user data private as we say they are, but also to see if they are practical within different federated learning environments. To test this, simple implementations/simulations of some or all of the security levels recommended here in cross silo and cross device federated learning could be very beneficial. By comparing the results of these experiments to the baseline performance of

federated learning without any security measures, we could get a better sense of the trade-offs between privacy, security, and model accuracy, and identify areas where further improvements are needed. As we mentioned earlier in this report, the goal behind this research was to provide security levels that would allow a finer grained security approach to federated learning for times when parties might not need all the slow but secure promises in current privacy preserving frameworks. Based on previous research we've outlined, we believe each of our 4 security levels is slower but more secure than the last. However, concrete evidence of this, measured in experiments, could provide further legitimacy to these claims. This research could also lead to further refinement and improvements of the techniques and strategies used to protect user data.

4.0 Literature Review

A small subset of the papers reviewed over the course of this project are summarized below. We chose these papers to include because of their contribution in not only our understanding of federated learning, but also the very development of the defenses recommended in this paper. We'd like to extend our gratitude to all the researchers who participated in these papers, as well as those listed in our references, for their hard work and dedication to advancing the field of privacy-preserving federated learning. We look forward to seeing continued progress in this field and the development of even more innovative solutions to address the complex challenges facing federated learning.

4.1 APPFL: Open-Source Software Framework for Privacy-Preserving Federated Learning

The first paper we will be looking at is "APPFL: Open-Source Software Framework for Privacy-Preserving Federated Learning" by Ryu et al. This paper discusses a framework to allow for federating learning that keeps a level of privacy for the training data. Essentially, federated learning (FL) is a type of ensemble learning where different models are trained on different local sites, resulting in each node sending a final weight over to a central location rather than sending its data (which would traditionally be aggregated among all nodes and then used to train a machine learning model directly). This is crucial as no actual data is shared, preventing potential leakage of data to malicious entities. However, FL is not perfect since the weights sent from nodes to the central server and other information may be aggregated and used to reconstruct (or summarize) the original data. To introduce privacy to FL, privacy-preserving techniques have been integrated into the FL algorithms, which is called PPFL. This paper introduces Argonne Privacy-Preserving Federated Learning (APPFL) framework that provides APIs to implement algorithmic components required for PPFL in a plug-and-play manner. These can be used for simulations on high-performance computing architecture and run on heterogeneous architectures. This framework also allows for a communication-effective IADMM algorithm that reduces the communication required, helping reduce privacy risks. Another feature of this framework is that it adds Laplacian noise to the local model parameters before sending them to the server. Overall, the results of the study showed high performance relative to other PPFL frameworks. This paper

overall described the basics of federated machine learning and privacy-enhancing features that could be implemented. This sets up context for the area our project will fit in.

4.2 Poisoning Deep Learning based Recommender Model in Federated Learning Scenarios

The second paper we will be reviewing is “Poisoning Deep Learning based Recommender Model in Federated Learning Scenarios” by Rong et. al. The paper essentially discusses the various ways attacks can be done in the context of federating learning, namely related to data poisoning. This is done via poisoned gradients that malicious users can send out, which are often done through random approximation or hard user mining. For example, in the context of recommender systems, malicious entities may want to promote target items to users by raising the overall predicted score of those items. This can be done through injecting fake interaction into the training data (or even generating false data that generates a specific gradient in a FL system). One type of attack is called random approximation (A-ra) and the other is hard user mining (A-hum). Random approximation can seek to approximate the users’ embedding vectors via normal distribution, whereas hard user mining can infer the output of “hard” (benign) users in order to generate poisoned gradients. This paper explained the techniques that can be used by malicious entities to poison the overall FL system, which usually involves maliciously constructed data. We might not only want to determine how identifiable data is in our project, but potentially if that data is fake or malicious. We next refer to the paper: “A survey on security and privacy of federated learning” by Mothukuri et. al. One security risk mentioned is generating data that is similar to private training data by malicious parties using just the information about the gradients. If the data itself was sensitive (such as average blood pressure levels for a patient with heart disease), a malicious party generating this information is a major compromise of privacy. In FL, to help combat the retrieval of information like gradients in communication, certain encryption algorithms are used to encrypt the data being sent. This is the foundation of SMC (Secure Multi-party Computation). Differential Privacy (DP) perseveres privacy by adding noise to personal sensitive attributes to preserve user privacy. Both of these papers highlight the risks of data poisoning and data generation in a FL system, as well as some techniques used to encrypt/protect the outgoing data.

4.3 Scanning Electronic Documents for Personally Identifiable Information

Related to actually discovering what data is considered personally-identifiable, we look at information from papers and websites related to this task. In the paper titled: “Scanning Electronic Documents for Personally Identifiable Information” by Aura et. al., techniques related to scanning text (which is often training data) and trying to flag information suspected of being identifiable are discussed. The most basic component to this is a regular expression matcher for information like usernames/identifiers, security ids, emails, mailing address, telephone numbers, DNS information, device names/identifiers, organization names/identifiers, and online services (similar to watermarks) used in the authoring process. This is done through storing common patterns in a database and marking those tags with data encodings. One difficulty here however

can be identifying false positives and negatives since the system doesn't technically ask the user to input what information they consider identifiable. This is usually done via pattern matching or comparison to databases of examples of information that is identifiable. There are however instances where PII is hidden (metadata) like human-readable metadata, machine-readable metadata, tracked changes, human-created comments, hyperlinks, metadata in embedded objects, names of paths of linked objects, template/style names, and macros/scripts. The authors of this paper explain how in a test, only 3 of 43 submissions hadn't been anonymized (done by first finding PII). We next look at a document titled "Identifying and handling personally identifiable information (PII)" on the AWS website. Tools like Amazon Comprehend are able to determine PII via NLP/text processing techniques, which allow them to mark a particular subtext as an entity (with a probability), which is marked then as PII if that probability exceeds a threshold. Once this PII data is identified, it can be masked by substitution, shuffling, deterministic encryption, probabilistic encryption, decryption, nulling out/deletion, masking out, and hashing. Finally, we will look at the document by Google Cloud called "De-identification and re-identification of PII in large-scale datasets using Cloud DLP". This document discusses how to create an automated data transformation pipeline to de-identify sensitive data. First, methods based on regular expression matching and intelligent text parsing are used to break down a text into a table consisting of PII estimated identifier and the actual text (for example: Name - "Jon Snow"). Then, PII is masked using redaction (remove the sensitive content with no replacement of content), masking (replace the sensitive content with fixed characters), and encryption (replace sensitive content with encrypted strings, possibly reversibly). In conclusion, these papers and documents discuss how to identify sensitive data and how to properly mask it to enhance privacy.

4.4 Threats to Federated Learning: A Survey

Named Entity Recognition is the process of identifying and categorizing entities in text such as person names, organizations, and locations. The authors discuss the different approaches to NER using deep learning, including methods based on convolutional neural networks (CNNs), recurrent neural networks (RNNs), and transformer models. They also provide a comprehensive review of various deep learning architectures and techniques for improving the performance of NER models. Privacy leakage is an issue: a malicious server may observe individual updates, manipulate the training process, and control the view of participants on the global parameters. Meanwhile, any participant may observe the global parameters and manipulate their parameter uploads, potentially introducing backdoors into the global model or altering their inputs in a harmful manner. These vulnerabilities could compromise the integrity of FL protocols and undermine their effectiveness. Insider attacks (FL server/FL participants) include single attack (a single, non-colluding malicious participant aims to cause the model to miss-classify a set of chosen inputs with high confidence), Byzantine attack (the byzantine malicious participants may behave completely arbitrarily and tailor their outputs to have similar distribution as the correct model updates, making them difficult to detect), Sybil attack (the adversaries can

simulate multiple dummy participant accounts or select previously compromised participants to mount more powerful attacks on FL). The most recent work called Deep Leakage from Gradient (DLG) proposed an optimization algorithm that can obtain both the training inputs and the labels in just a few iterations.

4.5 FLCert: Provably Secure Federated Learning against Poisoning Attacks

The authors of this paper propose FLCert, a federated learning system that uses a novel certification mechanism to ensure the integrity of the training data. FLCert combines a homomorphic encryption scheme with a cryptographic certification protocol to enable each participant to verify the correctness of the data contributed by other participants. This helps to prevent malicious actors from injecting incorrect data into the model.

The authors prove the security of FLCert against both non-colluding and colluding attackers under standard cryptographic assumptions. They also conduct experiments to evaluate the performance and effectiveness of FLCert on several benchmark datasets. The results show that FLCert achieves high accuracy while providing strong protection against poisoning attacks.

The FLCert algorithm involves the following steps. Initialization: The server initializes the model parameters and shares them with the participating clients, Data preparation: Each client uses its private data to compute the local update of the model parameters, encrypted using the homomorphic encryption scheme, Data aggregation: The server collects the encrypted local updates from each client and aggregates them using a secure aggregation protocol, Certification: Each client verifies the correctness of the aggregated update using a cryptographic certification protocol. The certification protocol enables each client to check that the aggregated update is a correct aggregation of the local updates submitted by all participants, Model update: The server updates the model parameters with the aggregated update only if all clients certify the correctness of the aggregated update. Otherwise, the update is discarded.

4.6 A Taxonomy of Attacks on Federated Learning

We have referenced this paper frequently throughout our research as a good overview of possible attacks and defenses currently available in federated learning. It gives a general overview of attacks currently documented to be successful against federated learning implementations and some of their defenses. One interesting thing it noted that prompted more research is that there is a “critical and challenging tradeoff between the privacy of training data and the utility of the model”. We later learned this is because several federated defenses harm the accuracy of the model. For example, differential privacy by design adds noise to the data in order to protect against an untrusted central server that aggregates the submitted client weights, thus harming the overall accuracy of the model. Of the attacks listed in the paper, their effects fell into one of five categories: malicious gradients, model back door, data poisoning, model poisoning, and test accuracy. The paper also gave brief overviews of defense strategies that currently exist in federated learning, namely differential privacy, robust aggregation, and outlier detection.

5.0 Bibliography

- [1] Ryu, M., Kim, Y., Kim, K., & Madduri, R. K. (2022, May). *APPFL: Open-Source Software Framework for Privacy-Preserving Federated Learning*. In *2022 IEEE International Parallel and Distributed Processing Symposium Workshops (IPDPSW)* (pp. 1074-1083). IEEE.
<https://doi.org/10.48550/arXiv.2202.03672>
- [2] Rong, D., He, Q., & Chen, J. (2022). *Poisoning Deep Learning based Recommender Model in Federated Learning Scenarios*. <https://doi.org/10.48550/arXiv.2204.13594>
- [3] Mothukuri, V., Parizi, R. M., Pouriyeh, S., Huang, Y., Dehghantanha, A., & Srivastava, G. (2021). *A survey on security and privacy of federated learning*. *Future Generation Computer Systems*, 115, 619-640. <https://doi.org/10.1016/j.future.2020.10.007>
- [4] Tuomas Aura, Thomas A. Kuhn, and Michael Roe. 2006. *Scanning electronic documents for personally identifiable information*. In *Proceedings of the 5th ACM workshop on Privacy in electronic society (WPES '06)*. Association for Computing Machinery, New York, NY, USA, 41–50. <https://doi-org.libproxy.utdallas.edu/10.1145/1179601.1179608>
- [5] Amazon Web Services. 2022. *Identifying and handling personally identifiable information (PII)*.
<https://docs.aws.amazon.com/databrew/latest/dg/personal-information-protection>
- [6] Google Cloud. 2022. *De-identification and re-identification of PII in large-scale datasets using Cloud DLP*.
<https://docs.aws.amazon.com/databrew/latest/dg/personal-information-protection>
- [7] M. S. Jere, T. Farnan and F. Koushanfar, "A Taxonomy of Attacks on Federated Learning," in *IEEE Security & Privacy*, vol. 19, no. 2, pp. 20-28, March-April 2021, doi: 10.1109/MSEC.2020.3039941.
- [8] Mothukuri, V., Parizi, R. M., Pouriyeh, S., Huang, Y., Dehghantanha, A., & Srivastava, G. (2021). *A survey on security and privacy of federated learning*. *Future Generation Computer Systems*, 115, 619-640. <https://doi.org/10.1016/j.future.2020.10.007>
- [9] Lingjuan L., Han Y., & Qiang Y. (2020). *Threats to Federated Learning: A Survey*.
<https://arxiv.org/pdf/2003.02133>
- [10] Xiaoyu C., Zaixi Z., Jinyuan J., and Neil G. (2022). *FLCert: Provably Secure Federated Learning against Poisoning Attacks*. <https://arxiv.org/pdf/2210.00584>

[11] "The Federal Register," Code of Federal Regulations. [Online]. Available: <https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164>. [Accessed: 28-Apr-2023].

[12] National Institute of Standards and Technology (2018) Risk Management Framework for Information Systems and Organizations. (Department of Commerce, Washington, D.C.), Special Publication 800-175B, Revision 1 December 2018. <https://doi.org/10.6028/NIST.SP.800-37r2>

[13] National Institute of Standards and Technology (2018) Guideline for Using Cryptographic Standards in the Federal Government. (Department of Commerce, Washington, D.C.), Special Publication 800-175B, Revision 1 March 2020. <https://doi.org/10.6028/NIST.SP.800-175Br1>

[14] S. Balakrishnan, Ravi Rajwar, M. Upton and K. Lai, "The impact of performance asymmetry in emerging multicore architectures," 32nd International Symposium on Computer Architecture (ISCA'05), Madison, WI, USA, 2005, pp. 506-517, doi: 10.1109/ISCA.2005.51.

[15] National Institute of Standards and Technology (2019) Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations. (Department of Commerce, Washington, D.C.), Special Publication 800-52, Revision 2 August 2019. <https://doi.org/10.6028/NIST.SP.800-52r2>

[16] National Institute of Standards and Technology (2019) Recommendation for Key Management. (Department of Commerce, Washington, D.C.), Special Publication 800-57, Revision 5 May 2020. <https://doi.org/10.6028/NIST.SP.800-57pt1r5>

[17] Peter Kairouz; H. Brendan McMahan; Brendan Avent; Aurélien Bellet; Mehdi Bennis; Arjun Nitin Bhagoji; Kallista Bonawit; Zachary Charles; Graham Cormode; Rachel Cummings; Rafael G. L. D'Oliveira; Hubert Eichner; Salim El Rouayheb; David Evans; Josh Gardner; Zachary Garrett; Adrià Gascón; Badi Ghazi; Phillip B. Gibbons; Marco Gruteser; Zaid Harchaoui; Chaoyang He; Lie He; Zhouyuan Huo; Ben Hutchinson; Justin Hsu; Martin Jaggi; Tara Javidi; Gauri Joshi; Mikhail Khodak; Jakub Konečný; Aleksandra Korolova; Farinaz Koushanfar; Sanmi Koyejo; Tancrede Lepoint; Yang Liu; Prateek Mittal; Mehryar Mohri; Richard Nock; Ayfer Özgür; Rasmus Pagh; Hang Qi; Daniel Ramage; Ramesh Raskar; Mariana Raykova; Dawn Song; Weikang Song; Sebastian U. Stich; Ziteng Sun; Ananda Theertha Suresh; Florian Tramèr; Praneeth Vepakomma; Jianyu Wang; Li Xiong; Zheng Xu; Qiang Yang; Felix X. Yu; Han Yu; Sen Zhao, *Advances and Open Problems in Federated Learning*, now, 2021.

[18] H. Fang and Q. Qian, "Privacy Preserving Machine Learning with Homomorphic Encryption and Federated Learning," *Future Internet*, vol. 13, no. 4, p. 94, Apr. 2021, doi: 10.3390/fi13040094.

- [19] J. Ma, S.-A. Naas, S. Sigg, and X. Lyu, 'Privacy-preserving federated learning based on multi-key homomorphic encryption', *International Journal of Intelligent Systems*, vol. 37, pp. 5880–5901, 2021.
- [20] F. Boenisch, A. Dziedzic, R. Schuster, A. S. Shamsabadi, I. Shumailov, and N. Papernot, 'Reconstructing Individual Data Points in Federated Learning Hardened with Differential Privacy and Secure Aggregation', 2023.
- [21] M. Yang, H. Cheng, F. Chen, X. Liu, M. Wang, and X. Li, "Model poisoning attack in differential privacy-based Federated Learning," *Information Sciences*, vol. 630, pp. 158–172, Jun. 2023.
- [22] K. Pillutla, S. M. Kakade, and Z. Harchaoui, 'Robust Aggregation for Federated Learning', *arXiv [stat.ML]*. 2022.
- [23] S. Fu, C. Xie, B. Li, and Q. Chen, 'Attack-Resistant Federated Learning with Residual-based Reweighting', *arXiv [cs.LG]*. 2021.
- [24] C. Xie, Y. Long, P.-Y. Chen, and B. Li, 'Uncovering the Connection Between Differential Privacy and Certified Robustness of Federated Learning against Poisoning Attacks', *arXiv [cs.CR]*. 2022.
- [25] R. Xu, N. Baracaldo, Y. Zhou, A. Anwar, and H. Ludwig, 'HybridAlpha: An Efficient Approach for Privacy-Preserving Federated Learning', in *Proceedings of the 12th ACM Workshop on Artificial Intelligence and Security*, London, United Kingdom, 2019, pp. 13–23.
- [26] Y. Li, Y. Zhou, A. Jolfaei, D. Yu, G. Xu and X. Zheng, "Privacy-Preserving Federated Learning Framework Based on Chained Secure Multiparty Computing," in *IEEE Internet of Things Journal*, vol. 8, no. 8, pp. 6178-6186, 15 April15, 2021, doi: 10.1109/JIOT.2020.3022911.
- [27] H. Zhou, G. Yang, H. Dai and G. Liu, "PFLF: Privacy-Preserving Federated Learning Framework for Edge Computing," in *IEEE Transactions on Information Forensics and Security*, vol. 17, pp. 1905-1918, 2022, doi: 10.1109/TIFS.2022.3174394.